

데모핀테크 정보보호 및 개인정보보호 정책서 (v2.1)

제정일 2022 - 03 - 02 、 최종 개정일 2024 - 11 - 15 、 승인 대표이사 、 문서번호
SEC - POL - 001

제1장 총칙

제1조(목적) 본 정책은 데모핀테크가 제공하는 간편송금 및 마이데이터 연계 서비스의 정보자산을 안전하게 보호하고, 개인정보를 적법하고 안전하게 처리하기 위하여 필요한 기본 방침과 기준을 정함을 목적으로 한다.

제2조(적용범위) 본 정책은 데모핀테크의 임직원 25명 전원, 서비스 개발·운영에 사용되는 AWS 서울 리전 단일 계정의 모든 자원, 그리고 업무를 위탁받은 수탁사에 적용한다.

제3조(용어의 정의) 정보자산이란 조직이 보유한 정보와 이를 처리하는 설비·소프트웨어를 말한다. 개인정보란 살아 있는 개인을 알아볼 수 있는 정보를 말한다.

제2장 정보보호 조직과 책임

제4조(최고책임자) 대표이사는 정보보호 최고책임자(CISO)와 개인정보 보호책임자(CPO)를 지정하고 그 지정 사실을 사내에 공지한다. 현재 CTO가 두 직책을 겸임한다.

제5조(정보보호위원회) 정보보호위원회는 대표이사를 위원장으로 하고 CISO, 개발팀장, 운영팀장으로 구성하며 분기 1회 정기 개최한다. 위원회는 정보보호 계획과 위험수용수준을 심의·의결한다.

제6조(실무 조직) 정보보호 실무는 CISO 직속의 보안담당자 1명이 겸직으로 수행한다. [본 조항은 조직 개편에 따라 개정 예정이며 세부 역할과 책임은 아직 확정되지 않았다.]

제3장 인적 보안

제7조(비밀유지) 전 임직원은 입사 시 비밀유지 서약서를 제출하며, 퇴직 시 재차 확인한다.

제8조(교육) 전 임직원은 연 1회 이상 정보보호 및 개인정보보호 교육을 이수하여야 한다.
개인정보취급자는 연 2회 이상 교육을 이수한다.

제4장 접근통제

제9조(계정관리) 정보시스템 계정은 업무상 필요한 최소한의 권한만 부여하며, 공용 계정 사용을 금지한다. 계정 신청과 승인은 이슈 트래커의 접근권한 신청 양식으로 기록한다.

제10조(사용자 인증) 운영 시스템 접근에는 아이디와 비밀번호를 사용한다. 비밀번호는 영문·숫자·특수문자를 조합해 10자리 이상으로 설정하고 분기마다 변경한다.

제11조(권한 검토) 정보시스템 접근권한의 적정성은 분기 1회 검토하고 결과를 기록·보관한다.

제5장 암호화

제12조(전송구간 암호화) 서비스와 이용자 단말 사이의 모든 통신은 TLS 1.2 이상으로 암호화한다.

제13조(저장 암호화) 주민등록번호, 계좌번호, 비밀번호는 안전한 알고리즘으로 암호화하여 저장한다. 비밀번호는 복호화되지 않는 일방향 함수를 사용한다.

제6장 운영보안

제14조(변경관리) 운영 환경의 변경은 별도의 변경관리 절차서에 따라 신청·승인·적용·검증 단계를 거친다.

제15조(로그 관리) 정보시스템의 접속기록은 최소 1년간 보관하며, 개인정보처리시스템의 접속기록은 관계 법령이 정하는 기간 동안 보관한다.

제16조(백업) 중요 정보와 데이터베이스는 정기적으로 백업한다. 세부 주기와 보관 방법은 백업 정책 문서에서 정한다.

제7장 침해사고 대응과 업무연속성

제17조(침해사고 대응) 침해사고 발생 시 침해사고 대응 절차서에 따라 신고·분석·복구·재발방지 절차를 수행한다.

제18조(업무연속성) [본 조항은 미작성 상태이다. 재해복구 목표시간(RTO)과 목표복구시점(RPO), 비상시 대응 조직과 모의훈련 계획은 차기 개정 시 반영한다.]

제8장 정책의 관리

제19조(검토와 개정) 본 정책은 연 1회 이상 적정성을 검토하고 필요 시 개정한다. 개정 시 정보보호위원회의 심의를 거쳐 대표이사가 승인한다.

제20조(위반 시 조치) 본 정책을 위반한 임직원에게 대해서는 사규가 정하는 바에 따라 징계할 수 있다.

부칙 본 정책은 2024년 11월 15일부터 시행한다. 개정 이력: v1.0(2022 - 03 - 02 제정), v2.0(2023 - 09 - 01 개인정보 항목 반영), v2.1(2024 - 11 - 15 접근통제 장 보강).